EWB

COURSES

AI-POWERED CYBERSECURITY

NAME: SHRITI SHRIYA

BATCH: CYBERSECURITY 01

Task A | Secure a student account

A1/A2. A table with Risk | Asset | CIA impact | Control | Limitation

RISK	ASSET	CIA IMPACT	CONTROL	LIMIATION
Same short password for emails and learning portals	Email accounts and leaning portals account	**Confidentiality:** Attackers could excess personal data and coursework. **Integrity:** They could alter account settings and delete or alter assignments.	Use a strong, unique password for each account and store them in a password manager.	User may forget complex passwords if a password manager is not used.
Approving unexpected sign-in prompts	Online accounts and personal information	**Confidentiality:** Attackers may gain account access. **Integrity:** Account settings or contents can be modified.	Enable MFA (Multi-factor Authentication) and only approve expected sign-in requests.	MFA can still be bypassed if user approve fraudulent prompts.
Postponing device updates	Laptop operating system and applications	**Confidentiality:** Unpatched vulnerabilities allow malware to steal sensitive data. **Integrity:** Attackers can modify via ransomware. **Availability:** Exploits can cause system failure.	Turn on automatic updates and install security patches promptly.	Updates may occasionally cause compatibility issues or required downtime.
Keeping only one copy of projects on the laptop	Project data and files	**Availability:** Hardware failure, physical theft, or ransomware immediately blocks all access to the work.	Create regular backups using cloud storage or an external device.	Backups require storage space and may become outdated if not performed regularly.
Friend using the laptop under Mira's	Personal accounts,	**Confidentiality:** Unauthorized data access.	Create separate user accounts and	User could still share passwords or

signed-in account	files and coursework	**Integrity:** Accidental file deletion/modification. **Availability:** Potential account lockout.	lock the device when not in use.	forget to lock the device.

A2. The first three prioritize actions are as follows:

1. **Change passwords and use strong, unique passwords.**
   This is the highest priority because a weak reused password creates an immediate risk to multiple accounts. If one account is compromised, the attackers may access both the email and learning portals.
2. **Stop approving unexpected sign-in prompts**
   Once passwords are secured, MFA adds another layer of protection. Preventing accidental approvals of fraudulent prompts significantly reduces the chances of account takeover.
3. **Install pending updates and enable automatic updating**
   Updating the laptop closes known vulnerabilities that attackers could exploit. Even strong passwords cannot protect a device with serious unpatched flaws.

A3. Authentication VS Authorization

- **Authentication**
  It is the process of verifying a user's identity. Like here when Mira enters her username, password and MFA code to log in to the learning portal, the system checks if she's really the owner.

- **Authorization**
  It is the process of determining what an authenticated user is allowed to do. After Mira logs in the learning portal may allow her to view course materials, submitted assignments and see her grade card but she can't access another student's records. These permissions are determined through authorization.

Task B | Analyze a suspicious message

B1. A warning-sign table is as follows:

Evidence	Explanation for scrutiny	Risk
"FINAL WARNING- scholarship expires in 20 minutes"	This creates urgency and pressure, encouraging the student to act quickly without verifying the message. Urgency is a common characteristic of phishing attempts.	High
"enter your college password and OTP"	Requests sensitive authentication information that could allow an attacker to access the student's account	High
"Do not contact the college office"	Discouraging independent verification is a warning sign. Genuine organizations encourage official channel.	High
"Reply with a photo of your identity card"	The message requests sensitive information that could be used for identity theft or account fraud.	High
Reply-To: help@personal-awards.example"	The reply address differs from the sender's address and uses a different domain.	Medium

B2. A number verification plan is as follows:

1. Do not click the link or provide any personal information.
2. Open the college's official website by typing the known address (campus.example) directly into the browser.
3. Log in through the official student portal and check for scholarship notification.
4. Contact the college scholarship department using an independently obtained phone or email address from the official website.
5. Report the suspicious message to the college IT/security team.

- HTTPS and a familiar display name do not guarantee that a message is genuine. HTTPS indicates that the connection between the browser and the website is encrypted, but it does not confirm that the website belongs to the college or is trustworthy. A phishing website can also use HTTPS. Similarly, familiar display name can be spoofed or impersonated by an attacker to make the message appear

legitimate. Therefore, the sender's identity and website should be verified through ana independently obtained official college contact or portal before providing any sensitive information.

B3. A response plan for a student who already entered the password and OTP is as follows:

1. Immediately change the affected account password using the official college portal.
2. Notify the college IT help desk or security team and report the incident as soon as possible.
3. Sign out of all active sessions if the service provides that option.
4. Review account activity for unknown logins, changed settings, or unauthorized actions.
5. Update MFA settings and ensure that only authorized devices are registered.
6. Monitor email and student accounts for suspicious activity or unexpected password reset requests.
7. Follow any additional instructions provided by the college IT or security team.

B4. The one important fact I cannot establish from the message alone is whether the scholarship is genuinely approved or whether the sender is actually associated with the college. Additional evidence that would help includes:

- Confirmation from the official college administration.
- Information from the college's official portal.
- Technical evidence such as website ownership records, security logs, or email authentication results.

Task C | Triage a sign-in alert

C1. Four-point timeline is as follows:

Time (IST)	Observed Evidence	Interpretation
09;00-09:01	Password succeeded and MFA was approved from 192.0.2.10	This appears consistent with the student's normal classroom login because the lab notes identify 192.0.2.10 as the usual classroom egress location.

10:14-10:16	Two password failures followed by a password success from 198.51.100.23.	This indicates a login attempt from a different source of IP. A different IP alone does not prove malicious activity, but it requires investigation because the student states they did not sign-in after 09:05.
10:17-10:18	MFA was denied, then approved. The user admits approving a prompt but denies initiating a sign-in.	The pattern suggests repeated authentication activity. The student statement that they approved a prompt at approximately 10:18 because they wanted the prompts to stop is consistent with MFA fatigue or accidental approval.
10:20	A session was created from 198.51.100.23. The user says they did not sign-in after 09:05.	This can be potential unauthorized access; the session activity and validity need verification.

C2.

- **Likely explanation:** The most likely explanation is that an unauthorized party obtained or knew the user's password and generated repeated MFA requests. The student then approved a prompt, allowing a session to be created.
- **Alternative explanation:** An alternative possibility is that the student may have unknowingly triggered the authentication attempts from another device, application, or network, resulting in legitimate login activity.

The list of two additional checks is as follows:

1. Review account audit logs to determine what actions occurred during the session created at 10:20.
2. Examine devices, browser and application information associated with the logins and compare them with the student's known devices.

C3. The three priority response actions are as follows:

1. Secure the account immediately by active sessions, force a password reset, and require MFA re-registration. This reduces the risk of continued unauthorized access.
2. Retain authentication logs, session records, audit logs, and related security alerts before making major changes. Evidence preservation is important for investigation and potential disciplinary or security procedures.
3. Review actions performed during the suspicious session, including file access, account changes, message activity and privilege changes. This helps determine the scope and impact of the incident.

C4. **Incident summary:**

On18 October 2026, student07 experienced suspicious sign-in activity from IP address 198.51.100.23. Two password attempts failed before a successful attempt, followed by an MFA denial, an approval and session creation at 10:20 IST. The user denies signing in after 09:05 but confirms approving an MFA prompt. The pattern suggests possible credential compromise and MFA fatigue or social engineering, although unauthorized access is not confirmed. The priority is to preserve authentication evidence, secure the account, revoke active sessions and investigate the session's subsequent activity.

Task D | Review an AI security answer

D1. The identified and corrected unsafe or unsupported claims/actions from the AI output are as follows:

1. Claim - "The email is safe because it uses HTTPS."
   Correction – HTTPS only encrypts data in transit; it does not guarantee the sender or the content of the email is safe. A phishing site can easily use HTTPS to secure their connection but the email may still contain malware or malicious links.
   Reference – Cybersecurity and infrastructure security agency (CISA) guidelines states that HTTPS protects confidentiality between server and the user but does not validate the legitimacy or the safety of the hosted content.
2. Claim - "The sign-in logs prove that the person using 198.51.100.23 stole the password."
   Correction – The IP address does not prove any malicious intent as they can be shared or rooted through a VPN or proxy. An IP address merely indicates the network endpoint used to connect. The actual theft occurred via malware or phishing prior to the login attempt.

Reference - NIST SP 800-86 (Guide to Integrating Forensic Techniques into Incident Response) establishes that IP addresses alone are insufficient for definitive attribution without corroborating forensic evidence.

3. Claim - "MFA prevents every account compromise."
   Correction – MFA significantly reduces risk but it does not prevent all compromises. Threat actors routinely bypass MFA using sophisticated techniques such as MFA fatigue attacks (prompt bombing), session hijacking (cookie theft), adversary-in-the-middle (AiTM) phishing proxies, and SIM swapping.
   Reference - CISA and the FBI have issued joint cyber advisories explicitly warning organizations about advanced persistent threats (APTs) successfully bypassing MFA via session token theft and MFA exhaustion tactics.
4. Action - " Delete the suspicious logs."
   Correction – Never delete the sign-in logs during an incident investigation destroys forensic evidence. Deleting logs prevents security teams from determining the full scope of the breach, identifying compromised data, establishing timelines, and conducting proper remediation.
   Reference – NIST SP 800-61 Rev. 2 (Computer Security Incident Handling Guide) emphasizes that preserving log data and maintaining chain of custody is critical for incident analysis and legal evidence.
5. Action - " and send the student's password to the support so that they can test it."
   Correction – Password should never be shared even to support staff. Sharing credentials increases security risks and violates good security practices.
   Reference - Standard institutional identity policies and NIST SP 800-63B (Digital Identity Guidelines) strictly prohibit the sharing or cleartext transmission of secret authenticators.

D2. Improved AI prompt

"Act as a cybersecurity analyst reviewing a synthetic sign-in alert. Analyze only the fictional evidence provided in this assignment. Do not use or request real student data, passwords, authentication codes, personal information or other secrets.Separate observed facts from assumptions and interpretations. Identify suspicious activity, provide a likely explanation and one alternative explanation, and recommend appropriate investigation and response actions.Do not identify an individual based only on an IP address. Do not assume that HTTPS guarantees safety or that MFA prevents every account compromise. Preserve uncertainty wherever the evidence is incomplete.Do not recommend deleting logs or sharing passwords. Explain the limitations of the available evidence and identify additional checks that could help confirm or reject the suspected incident."

D3. The suspicious sign-in activity should be investigated before confirming an account compromise. HTTPS does not guarantee that an email or website is legitimate, as phishing websites can also use encrypted connections. The authentication logs show two failed password attempts followed by a successful attempt from an unfamiliar IP address. The subsequent MFA denial, approval and session creation raise concern about possible credential compromise or MFA fatigue. However, an IP address alone cannot identify an attacker, and the available evidence does not establish who initiated the activity. The authorized IT team should preserve the authentication logs, revoke active sessions, reset the password securely and review MFA registrations. Further checks should examine device details, session activity and authentication records. Passwords must never be shared with support staff. Users should reject unexpected MFA prompts and report suspicious sign-in activity immediately.

D4. AI- use Declaration

AI tool used: ChatGPT

Purpose - Use ChatGPT to draft a safer AI prompt and prepare corrected cybersecurity advice. Assistance with structuring responses and improving clarity.

Reference:

1. The National Cyber Security Centre (NCSC) advises that phishing messages often use urgency, requests for credentials, and other social engineering techniques to obtain sensitive information.
2. The Cybersecurity and Infrastructure Security Agency (CISA) recommends enabling MFA, protecting passwords, and preserving evidence during incident investigations. MFA improves security but should not be considered a complete protection against all forms of compromise.